

DPIA input

A Data Protection Impact Assessment is the **controller's** (client's) duty. The client's DPO runs it; this document gives them the processing facts and a candid risk analysis so they can complete it quickly.

Draft for review. See README.md .

Is a DPIA required?

Likely **recommended** (and the client's DPO may treat it as required) because the processing combines: employees' free-text opinions, consumer participants, and **AI/innovative technology**. It is **not** automated decision-making with legal or similarly significant effect on individuals (Art. 22) — the AI designs product concepts; it does not make decisions about people. Note this clearly; it materially lowers the risk profile.

Processing description

See 01_data-flow-and-residency.md . In short: intake (names, roles, free-text answers, uploaded documents), AI-assisted analysis and concept generation, and a consumer test panel (first name, age, feedback). Controller: client. Processor: Unlockt. Sub-processors: Anthropic (US, AI), Vercel (EU), Turso (EU).

Necessity & proportionality

Purpose: improve the client's products/propositions for underserved (women) customers — a legitimate commercial purpose.

Data minimisation: panelists identified by first name + age only; assessment captured as numbers; AI receives only what each feature needs.

The US transfer is the minimum necessary to use the AI capability, covered by SCCs and no-training; an EU-residency path exists if required (01_...).

Risks to data subjects & mitigations

Risk	Who	Mitigation
Career-sensitive opinions exposed (crew criticising employer)	Crew	Access control; the morning "mirror" presents quotes anonymised ; short retention; data minimisation
Uploaded document contains third-party / sensitive data	Third parties	Instruction not to upload special-category data; short retention; access control
Consumer reveals personal financial circumstances	Panel	Explicit consent; first-name+age only; anonymised use of quotes; short retention
Transfer to US (Anthropic)	All AI-touched data	SCCs; no training; 30-day deletion; minimisation before sending

Risk	Who	Mitigation
AI inaccuracy / hallucination influencing decisions	Client	Human-in-the-loop: the facilitator reviews AI output (findings, research) before the room sees it; AI output is advisory, never auto-actioned
Unauthorised facilitator access	All	Auth on facilitator routes; gap: shared password / no audit log — see 05_... remediation

Residual risk

With the mitigations above, residual risk is **assessed as low-to-medium**, driven mainly by (a) the US transfer (managed by SCCs + no-training + 30-day deletion) and (b) the access-control gaps in 05_... (remediable before the first real client). The controller's DPO makes the final determination.

Consultation

If the DPO concludes residual risk remains high after mitigation, prior consultation with the Autoriteit Persoonsgegevens (Art. 36) may be warranted — the no-Art.-22 and human-in-the-loop points should weigh against that.